

FIREWALL MIKROTIK ET VPN SECURISES

Dossier de livraison
technique

Lab valide sous UTM sur
Apple Silicon
RouterOS CHR 7.22.1

Objectif

Construire et valider un pare-feu central pour le siege, un routeur de succursale et deux usages VPN: acces distant securise des employes et liaison securisee entre les deux sites.

Etat	Perimetre	Date de validation
VALIDE	Lab UTM complet et teste	26 juillet 2026

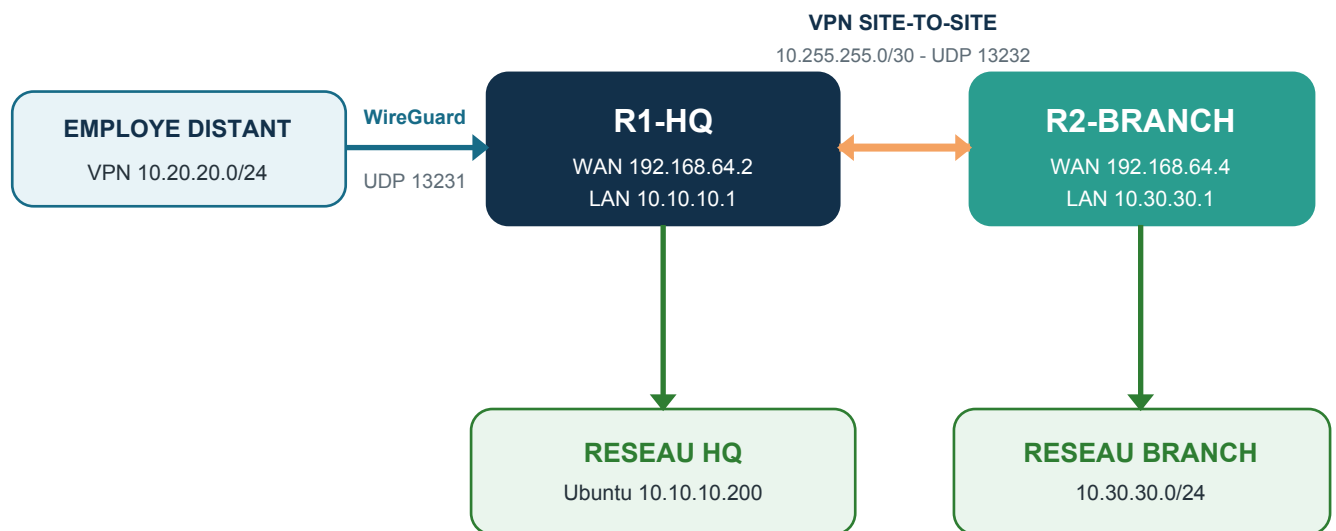
Important: ce document ne contient aucun mot de passe ni aucune cle private VPN. Les secrets doivent etre remis separement et stockes dans un gestionnaire de mots de passe.

1. Resume du resultat

Le lab simule une entreprise avec un siege (HQ), une succursale (Branch) et un employe externe. Les routeurs filtrent le trafic, donnent l'acces Internet aux reseaux internes et chiffrent les communications VPN.

- R1-HQ protege le reseau principal 10.10.10.0/24.
- R2-Branch protege le reseau de la succursale 10.30.30.0/24.
- VPN employes permet a un poste externe autorise d'entrer dans le reseau via WireGuard.
- VPN site-to-site relie HQ et Branch par un tunnel chiffre permanent.
- Politique firewall: ce qui est explicitement autorise passe; le reste est bloque par default.

2. Architecture validee



Lecture simple: R1-HQ est la porte principale du siege. R2-Branch est la porte de la succursale. WireGuard cree des tunnels chiffres entre les personnes/sites autorises.

3. Plan d'adressage

Element	Interface / role	Adresse ou reseau
R1-HQ	WAN UTM Shared	192.168.64.2/24
R1-HQ	Passerelle LAN HQ	10.10.10.1/24
Ubuntu HQ	Client / serveur de test	10.10.10.200/24
R2-Branch	WAN UTM Shared	192.168.64.4/24
R2-Branch	Passerelle LAN Branch	10.30.30.1/24
DHCP Branch	Plage clients	10.30.30.100 - 10.30.30.200
VPN employes	Reseau WireGuard	10.20.20.0/24
R1 VPN employes	Passerelle VPN	10.20.20.1
Employe test	Client VPN	10.20.20.2
VPN site-to-site	Transit WireGuard	10.255.255.0/30
R1 / R2 site-to-site	Extremities du tunnel	10.255.255.1 / 10.255.255.2

4. Machines virtuelles utiles

VM	Role	Etat recommande
MikroTik CHR Automated	R1-HQ - pare-feu principal	Demarrer
R2-Branch	Pare-feu de la succursale	Demarrer
HQ-Test-Client	Ubuntu du reseau HQ pour les tests	Demarrer pour les tests
Remote-Employee-Test	Simulation d'un employe externe	Arrete hors test VPN

Ne pas supprimer les anciennes VM existantes. Elles ne font pas partie du lab final, mais elles ont ete conservees conformement a la consigne.

5. Fonctionnement du firewall

Le firewall traite deux familles principales de trafic:

INPUT

Trafic qui vise le routeur lui-meme: WebFig, SSH, WinBox, ping vers la passerelle et ports WireGuard. Il protege l'administration et les services du routeur.

FORWARD

Trafic qui traverse le routeur: LAN vers Internet, VPN vers LAN, HQ vers Branch et Branch vers HQ. Il protege les machines placees derriere le routeur.

Ordre logique	Decision	Pourquoi
1	Accepter established / related	Laisser continuer les connexions deja autorisees et leurs flux associes.
2	Bloquer invalid	Rejeter les paquets incohérents ou impossibles a rattacher a une connexion valide.
3	Autoriser les besoins connus	LAN, administration controlee, WireGuard, HQ vers Branch et retour.
4	Drop final	Tout ce qui n'a pas ete explicitement autorise est refuse.

6. NAT masquerade

Les adresses 10.x.x.x sont privees et ne circulent pas directement sur Internet. La regle masquerade remplace temporairement l'adresse source privee par l'adresse WAN du MikroTik. Quand la reponse revient, le routeur sait a quel client interne la remettre.

Important: le trafic HQ - Branch ne doit pas etre masque. Les deux routeurs connaissent leurs reseaux par des routes WireGuard; ils conservent donc les vraies adresses internes pour faciliter le controle et les journaux.

7. Services d'administration

Service	Etat	Justification
SSH	Actif	Administration securisee en ligne de commande.
WebFig	Actif	Administration depuis le navigateur dans le lab.
WinBox	Actif	Administration MikroTik si necessaire.
Telnet, FTP, API, API-SSL, reverse proxy	Desactives	Reduction de la surface d'attaque.

8. VPN WireGuard

VPN employes - UDP 13231

Un employe externe possedant sa cle WireGuard peut obtenir l'adresse 10.20.20.2 et acceder uniquement aux ressources autorisees. Le test a ete effectue depuis une VM placee sur le reseau externe UTM, pas depuis le LAN HQ.

VPN site-to-site - UDP 13232

R1-HQ et R2-Branch possedent chacun une paire de cles independante. Le tunnel transporte 10.10.10.0/24 vers 10.30.30.0/24 sans NAT. Les routes et les regles firewall sont chargees automatiquement au demarrage.

9. Matrice de tests

Test	Resultat	Preuve observee
Employe externe sans VPN vers HQ	BLOQUE	Ping et SSH HQ inaccessibles.
Employe externe avec VPN vers HQ	OK	Handshake, ping et SSH reussis.
Employe VPN vers Internet	OK	Connectivite conservee pendant le test.
R2 transit vers R1	OK	10.255.255.2 vers 10.255.255.1: 0% perte.
Branch vers HQ Ubuntu	OK	10.30.30.1 vers 10.10.10.200: 0% perte.
HQ Ubuntu vers Branch	OK	10.10.10.200 vers 10.30.30.1: 0% perte.
Ubuntu HQ vers Internet	OK	Reponse HTTPS HTTP/2 200.
Redemarrage R2 puis R1	OK	Adresses, routes, firewall et tunnels revenus automatiquement.

Conclusion des tests: le comportement attendu est valide dans le lab: le trafic non autorise est bloque, les flux necessaires sont autorises et les VPN reviennent apres redemarrage.

10. Sauvegarde et restauration

Deux formats sont fournis pour chaque routeur:

- .backup: image binaire complete pour restaurer rapidement le meme routeur / la meme VM.
- .rsc: export texte lisible, utile pour l'audit, la documentation ou une reconstruction manuelle. Les informations sensibles ont ete masquees dans l'export final.

Routeur	Sauvegarde binaire	Export texte
R1-HQ	R1-HQ-final-validated.backup	R1-HQ-final-validated.rsc
R2-Branch	R2-Branch-final-validated.backup	R2-Branch-final-validated.rsc

Procedure de restauration

- Arrêter les changements et identifier le bon routeur.
- Importer le fichier .backup dans Files sur le routeur concerne.
- Lancer la restauration depuis System > Backup, puis laisser le routeur redemarrer.
- Verifier ensuite l'identite, les adresses IP, les interfaces, les routes, le firewall et les handshakes VPN.
- Ne jamais restaurer le backup R1 sur R2 ou inversement.

11. Exploitation quotidienne

Controle	Action attendue
Etat des VPN	Verifier le dernier handshake et les compteurs RX/TX WireGuard.
Alertes firewall	Verifier les compteurs des regles drop et les logs utiles.
Sauvegardes	Creer un backup avant chaque changement important et conserver une copie hors du routeur.
Mises a jour	Tester d'abord dans une copie du lab, sauvegarder, puis planifier la maintenance.
Comptes	Utiliser des comptes nominatifs et des mots de passe uniques; supprimer les acces des employes sortants.

12. Passage du lab a la production

Le lab prouve le fonctionnement technique, mais il ne faut pas copier aveuglement les adresses UTM en entreprise. La production doit etre adaptee au vrai plan reseau, aux fournisseurs Internet et aux exigences de securite de l'entreprise.

A valider avant production	Pourquoi
Materiel / hyperviseur supporte et redondance	Eviter qu'une seule panne coupe toute l'entreprise.
Vraies interfaces WAN et LAN	Remplacer le reseau Shared UTM par le cablage et les VLAN reels.
IP publique ou redirection UDP 13231/13232	Rendre les serveurs WireGuard joignables depuis l'exterieur.
DNS dynamique si IP WAN variable	Permettre aux clients VPN de retrouver le site apres un changement d'IP.
Restriction de WebFig / SSH / WinBox	Autoriser l'administration seulement depuis un VLAN ou des IP de gestion.
Certificat HTTPS valide	Proteger WebFig si son usage est maintenu.
MFA et gestion des identites	Renforcer l'accès des administrateurs et le cycle de vie des employes.
Journalisation et supervision	Detecter les pannes, tentatives d'intrusion et anomalies.
Test externe reel	Valider depuis une vraie connexion 4G/5G ou un autre FAI.
Plan de retour arriere	Pouvoir restaurer rapidement le service en cas d'echec.

Statut final: LAB FONCTIONNEL ET VALIDE. Le passage en production reste une operation separee qui doit etre planifiee avec l'entreprise et adaptee a son infrastructure reelle.

13. Durcissement complementaire

Une relecture complete des deux configurations exportees a ete menee apres la validation. Elle ne remet pas en cause la matrice de tests de la section 9: les flux autorises passent, les flux non autorises sont bloques. Elle identifie en revanche des points qui echappent a la politique default deny, ou qui restent invisibles dans un test de connectivite.

Les corrections ne sont pas appliquees. Elles sont livrees sous forme de deux scripts distincts, R1-HQ-hardening.rsc et R2-Branch-hardening.rsc. La configuration validee du 26 juillet 2026 reste intacte et demeure la reference.

Point principal: le plan de management de niveau 2

Le firewall decrit en section 5 filtre le trafic IP, c'est-a-dire la couche 3. Or RouterOS expose aussi deux services d'administration qui fonctionnent en couche 2, directement sur les adresses MAC: MAC-WinBox et MAC-Telnet. Ils permettent d'administrer un routeur qui n'a meme pas d'adresse IP.

Ces services ne traversent pas /ip firewall filter. La regle INPUT default deny ne les voit jamais, et ils sont actifs par default sur toutes les interfaces. Un poste situe sur le meme domaine de diffusion qu'une interface du routeur peut donc ouvrir une session d'administration sans qu'aucune regle de firewall n'intervienne.

La correction restreint ces services, ainsi que le protocole de decouverte de voisinage, a la seule liste d'interfaces LAN. L'accès WinBox par adresse IP n'est pas affecte: il releve de la couche 3 et reste soumis aux regles de la chaine input.

Points releves

Point	Nature	Effet sur le service
Management de niveau 2 (MAC-WinBox / MAC-Telnet) actif sur toutes les interfaces	Ajout	Aucune interruption.
Regles de rejet sans journalisation: aucune trace en cas d'incident	Modification de regles existantes	Aucune interruption.
MSS non ajuste sur les tunnels WireGuard (MTU 1420): risque de sessions TCP bloquee sans erreur lisible	Ajout	Aucune interruption.
Aucun client NTP: horodatage des journaux et validation TLS non fiables	Ajout	Aucune interruption.
Chaine input asymetrique entre R1 et R2 sur le tunnel site-a-site: fausse le diagnostic	Ajout	Aucune interruption.
Aucune regle dans /ipv6 firewall filter alors que le projet est entierement en IPv4	Parametre systeme	Redemarrage requis.
R1-HQ declare une troisieme carte reseau, pontee sur le reseau physique de l'hote, absente du plan d'adressage	Parametre d'interface	A verifier au prealable.

Gestion des secrets

La section 10 prevoit la remise des sauvegardes binaires. Contrairement aux exports texte .rsc, un fichier .backup contient l'integralite de la configuration, y compris les clees privees WireGuard et les hachages des mots de passe administrateurs. Il doit donc etre transmis par un canal separe et conserve dans un gestionnaire de mots de passe, au meme titre qu'un mot de passe.

Methode d'application

- Sauvegarder l'etat courant: /system backup save puis /export.
- Activer le Safe Mode du terminal RouterOS (Ctrl+X): si la session d'administration est interrompue, le routeur restaure automatiquement la configuration precedente.
- Appliquer les sections une par une, en verifiant apres chacune.
- Quitter le Safe Mode pour rendre les changements permanents.
- Rejouer la matrice de tests de la section 9 avant de considerer la nouvelle configuration comme validee.

Les points relevant du passage en production - restriction de WebFig, SSH et WinBox, comptes nominatifs, certificat HTTPS - restent traites en section 12 et ne sont pas repris ici. Le detail complet de cette relecture figure au chapitre 14 du resume du projet.

14. Contenu du dossier de livraison

- Le present dossier PDF.
- Les backups binaires finals de R1-HQ et R2-Branch, a transmettre par un canal separe (voir section 13).
- Les exports texte finals de R1-HQ et R2-Branch.
- Les deux scripts de durcissement complementaire, non appliques (voir section 13).
- Les VM UTM conservees sur le Mac pour demonstration et tests.

Fin du document